

御网智元技术报告

具备自主决策能力的通用网络安全智能体

版本日期：2026-08-29

项目摘要

御网智元是单机自托管、可审计的通用网络安全 Agent 工作台。用户以自然语言和附件提交任务，系统固化 TaskSpec、Provider/Profile/Tool 快照，由 Agent 进行规划、受控工具调用、观察、验证和报告收尾。

初审可直接验证的亮点是统一任务入口、动态规划与重规划、受控工具协同、Prompt Injection 防护、轨迹回放和独立评测。系统不把模型自述当事实，只有工具证据和确定性规则才能升级验证状态。

技术方案

输入经过统一消息入口进入 Run；Agent 依次完成任务说明、计划、策略检查、工具执行、观察/重规划、确定性验证和报告。附件与工具输出默认不可信，凭 Artifact ID 访问并受 Thread、大小、类型和授权约束。

已实现：文本/JSON/YAML/CSV、ZIP/TAR 安全摘要；localhost HTTP 探针；Flag 格式检查；Evidence/TaskResult；SQLite 审计与检查点恢复。可扩展：声明式 Skill、Python 插件、MCP。决赛后适配：主办方网关与平台判分接口。

系统架构与模块说明

React Web -> FastAPI 统一消息 API -> AgentEngine/LangGraph -> Provider 与 ToolRegistry -> PolicyEngine -> SQLite 事件、证据、报告和检查点。Artifact 存储与数据库分离，Run 保存不可变 TaskSpec、Provider/Profile/Tool 快照。

关键代码：apps/api/context.py、apps/api/routes/messages.py、src/yuwang/agent/engine.py、src/yuwang/tooling/executor.py、src/yuwang/policy/engine.py、src/yuwang/storage/。

自主决策与可解释性设计

模型只输出结构化计划/动作，服务端记录公开的目标、行动理由、工具参数摘要、观察事实、下一步决策和证据引用，不保存隐藏思维链。每个动作都有策略判定和状态事件；无进展、预算、超时、越权和不可信输出会触发停止或重规划。

可复查证据：Run events、ExecutionStep、EvidenceRecord、TaskResult、Markdown/JSON 报告；恢复从持久化检查点继续，不重放已完成调用。

工具协同与扩展机制

所有工具遵循 ToolSpec、输入/输出 Schema、风险、权限、超时、错误码和幂等契约，统一经 Registry、PolicyEngine、Executor 执行。内置 CTF 工具可串联 Artifact；MCP 仅允许管理员白名单命令或受控 HTTPS，禁止 Shell 解释器。

新增工具需实现 SDK Plugin、补契约/越权/失败测试，并声明可处理的 Artifact 类型；Run 启动时冻结工具快照。

安全设计与威胁模型

威胁包括路径穿越、符号链接、压缩炸弹、超大文本、MIME 伪装、Prompt Injection、SSRF、密钥泄漏和恢复重放。防护包括 Artifact ID 隔离、ZIP/TAR 文件数/单文件/总大小/压缩比限制、magic bytes 与扩展名/MIME 一致性、localhost 白名单、递归脱敏、CSRF、快照和幂等请求。

公网部署不能裸露本应用：需 HTTPS、带认证反向代理、临时账号、限流、隔离数据库/Artifact 目录和凭据轮换。

创新点与同类方案对比

核心创新是把可信验证、证据绑定、不可变快照、安全恢复和不可信工具输出处理做成可审计契约，而不是把模型大小或框架名称当创新。

公开工作对比（访问日期 2026-08-28；以下是公开仓库/论文描述，不是本项目的性能基线）：

| 工作 | 可核查来源与事实 | 本项目的边界差异 |

| --- | --- | --- |

| NYU CTF Bench | [GitHub](https://github.com/NYU-LLM-CTF/NYU_CTF_Bench)，公开 README 描述 200 个 CSAW CTF、6 类题型，并提供 Docker 化挑战 | 本项目当前只提供小型本地评测集，重点是证据、权限和可审计闭环，不声称覆盖其规模 |

| BoxPwnr | [GitHub](https://github.com/0ca/BoxPwnr)、[traces](https://boxpwnr.info/)，支持多个安全平台/solver 并公开轨迹 | 本项目不接入公网平台，轨迹只保存脱敏公开行动和证据引用，不保存隐藏思维链 |

| HackSynth | [GitHub](https://github.com/aielte-research/HackSynth)、[论文](https://arxiv.org/abs/2412.01778)，公开介绍 Planner/Summarizer 与 PicoCTF/OverTheWire 基准 | 本项目的创新主张不是 Planner 数量，而是不可变快照、工具策略检查和确定性验证 |

| D-CIPHER | [NYU agents 仓库](https://github.com/NYU-LLM-CTF/nyuctf_agents)中包含 D-CIPHER 相关实现/说明 | 当前不复现其结果，不将名称相同视为性能或方法等价 |

| CyberGym-E2E | [GitHub](https://github.com/sunblaze-ucb/cybergym-e2e)、[论文](https://arxiv.org/abs/2606.04460)，公开描述从漏洞发现、PoC 到补丁的端到端评测 | 本项目不执行真实项目漏洞利用或补丁评测，案例限定无害 localhost/附件 |

本项目没有足够同口径数据宣称优于上述工作；答辩只展示可复查的本地运行记录、失败记录和安全边界。